

National Institute of Business Management (NIBM)
Coventry University (CU)

NB5004CEM - Cybersecurity | Level 5 | 20 Credits

Cryptography Properties, Not Mechanics

Session 3 - S3 | Block 2 - Protection Mechanisms

Niranga Dharmaratna | niranga@nibm.lk

S3



Block 2 - Protection Mechanisms

Cryptography and Identity

Sessions 3, 4 and 5 - Cryptography / Authentication / Authorisation



Session Overview



What does cryptography achieve - and when is each tool the right choice?

- **Map four cryptographic properties to their mechanisms and use cases - Confidentiality, Integrity, Authenticity, Non-repudiation**
- **Distinguish Integrity from Authenticity: both can hold at the same time, either can fail independently**
- **Identify cryptographic misuse patterns and what property they violate**
- **Inspect a real TLS certificate and evaluate what it means for the Authenticity property**

**Learning
Outcome**

LO1

Evaluate encryption and authentication methods for a given set of requirements

3 hours - 1 hr theory | 45 min activity | 45 min lab

Where We Are - The Knowledge Chain



Session 1 - We named the five security properties

Confidentiality, Integrity, Availability, Authenticity, Accountability

Session 2 - We mapped threats to those properties

STRIDE gives us a two-way lookup: threat to property and property to threat class

Session 3 - Today: what mechanisms enforce those properties?

Cryptography enforces Confidentiality (encryption), Integrity (hashing), and Authenticity (digital signatures + certificates)

No maths. No algorithm internals. One question only - what does it achieve?

KEY CONCEPT



Properties, Not Mechanics

The question in this session is never: 'How does AES work?' or 'What is a hash function internally?'

It is always: 'What does this achieve - and when is it the right tool?'

No mathematical derivations. No algorithm internals. This is not a shortcut. It is exactly the lens a system evaluator uses when asking whether a real system's cryptographic choices are correct.



Four Cryptographic Properties



Property	What It Achieves	Mechanism
Confidentiality	Hides content from all parties without the key	Symmetric encryption (e.g. AES)
Integrity	Detects any change to a message or file	Hashing (e.g. SHA-256)
Authenticity	Proves the origin of a message or the identity of a server	Digital signatures and certificates
Non-repudiation	The sender cannot later deny having sent the message	Digital signatures (stronger Authenticity)

Availability is not enforced by cryptography. Its mechanisms (rate limiting, resilience, redundancy) arrive in Session 7.

Confidentiality - Symmetric Encryption



Property - Confidentiality

Information is accessible only to those authorised to see it

Mechanism - Symmetric encryption

The same key is used to encrypt and to decrypt

Encryption is REVERSIBLE - the key that locks the data can unlock it

Content is hidden from every party that does not hold the key

Analogy - The Sealed Safe

You place a document inside, spin the combination lock, and it is hidden from everyone without the combination. The combination is the encryption key. Anyone who holds the key can open the safe and retrieve the document. Symmetric encryption works exactly this way: one key, two directions - lock and unlock.

Confidentiality - Where It Appears



Data layer - encryption at rest

Database records, stored files, backups

Example: a healthcare record encrypted with AES - unreadable without the decryption key even if the storage volume is stolen

Network layer - encryption in transit via TLS

TLS wraps the connection in an encrypted channel between client and server

An attacker intercepting the traffic sees only ciphertext

What encryption does NOT do

It does not prove who sent the message (that is Authenticity). It does not detect tampering (that is Integrity). Those require different mechanisms.

Layers: Data (primary) - Network (TLS in transit) - SRS: DATA-01, NET-01

Integrity - Hashing



Property - Integrity

Information and systems are accurate and unaltered

Mechanism - Hashing

A hash function takes any input and produces a fixed-length digest (a fingerprint)

Hashing is ONE-WAY - the digest cannot be reversed to recover the original input

Use: verify that a file or message has not been altered

Analogy - The Wax Tamper Seal

A wax seal is formed from the contents of the letter. If anyone opens the envelope and reseals it, the wax pattern will be different - the tampering is detectable. Crucially, you cannot reconstruct the original letter from the seal alone. A hash is a digital wax seal: it proves the content arrived intact, but you cannot reverse it to see the content.

How Hashing Works - The Avalanche Effect



- Same input always produces the same output
- Any change to the input produces a completely different output
- Even changing one character transforms the entire digest - this is the avalanche effect
- The digest cannot be reversed - you cannot recover the input from the hash alone
- Common uses: verifying software downloads (integrity check), stored password verification (Application layer), detecting file tampering

Interactive Demo - Open [NB5004CEM_S3_Cryptography_Demo_AvalancheHasher.html](#) on your device. Type any text and change one character. Watch the entire SHA-256 digest transform. Then compare hashing (one-way) with encryption (reversible) side by side.

KEY CONCEPT

Integrity and Authenticity - Neither is Enough Alone

Integrity says: the message has not changed.

Authenticity says: it came from the right source.

Both can be true at the same time. Either can fail independently.

A file can arrive completely unaltered - but from the wrong sender.

A message can arrive from the right sender - but modified in transit.

Evaluating a system means checking both. They have different mechanisms and different failure modes.

Authenticity - Digital Signatures and Certificates



Property - Authenticity

An entity or message is genuinely what it claims to be

Mechanism 1 - Digital signatures

Signing uses a private key (only the owner can sign). Verification uses the corresponding public key (anyone can verify). A valid signature proves the message came from that specific entity.

Mechanism 2 - Certificates

A certificate binds a public key to an identity, issued by a trusted Certificate Authority (CA). It proves that the entity holding the key is who it claims to be.

Analogy - Passport and Signature

A passport (certificate) issued by a trusted government (CA) proves you are who you claim to be - not just anyone claiming that name. Your handwritten signature (digital signature) on a document proves it was you who signed it, not an impersonator. Together they answer: who sent this, and is that identity genuine?

Certificate Chains - Closing the S1 Loop

Session 1 introduced Authenticity as a property CIA misses. Session 3 names its mechanism.

A certificate chain traces trust from a server certificate back to a root CA

Root CA - trusted by browsers and operating systems; the anchor of the entire chain

Intermediate CA - issued by the root, issues your server certificate

Server certificate - presented to the client, proves the server is who it claims to be

What a broken chain means for the Authenticity property

Expired certificate - the server identity can no longer be verified by a trusted authority

Self-signed certificate - no trusted third party vouches for the identity

Certificate from an unrecognised CA - chain of trust is broken; browser warnings fire

Layer: Network - Property: Authenticity - SRS: NET-01, APP-01

Non-repudiation - Authenticity With Evidence



Non-repudiation is Authenticity with proof that cannot be withdrawn

The sender cannot later deny having sent the message

What makes it stronger than basic Authenticity

The private key used to sign belongs to one entity only - if the signature verifies, that entity signed it

No plausible deniability: the cryptographic proof is tied to the identity

Where this matters in the coursework domains

Banking: a transfer instruction cannot be denied by the account holder who signed it

Healthcare: a prescription or record change is tied to the clinician who authorised it

Connects to Accountability: when an action cannot be denied, it is fully attributable

Non-repudiation bridges Authenticity and Accountability - both properties from Session 1

Where Each Cryptographic Tool Appears



Layer	Tool	Property Enforced	Example
Data	Symmetric encryption	Confidentiality	Encrypted database records at rest
Network	TLS (uses symmetric + asymmetric)	Confidentiality	HTTPS - encrypted channel in transit
Network	Certificates + digital signatures	Authenticity	Server identity - real bank vs impersonator
Application	Hashing	Integrity	Stored password verification (S4 detail)
Any	Digital signatures	Non-repudiation	Signed transactions, audit records

Availability is not enforced by cryptography - its mechanisms (rate limiting, redundancy, resilient architecture) arrive in Session 7.

Misuse Patterns 1 and 2



Misuse 1 - MD5 or SHA-1 for password storage

MD5 and SHA-1 are fast by design - fast is wrong for passwords

A GPU can compute billions of MD5 digests per second - brute-forcing a stolen hash database is trivial

FAILURE: Authenticity fails - passwords cracked at scale means impersonation at scale

Misuse 2 - Encryption where hashing is needed, or hashing where encryption is needed

Encrypting passwords: they can be decrypted if the key is stolen - the whole database is exposed

Hashing a value that must later be retrieved: it cannot be recovered - the system breaks

FAILURE: the tool must match what the property actually requires - one-way vs two-way is a design decision

Note - the correct approach for password storage (bcrypt, Argon2, salting) is covered in Session 4

Misuse Patterns 3 and 4



Misuse 3 - Hardcoded encryption keys in source code

A key stored in the codebase is visible to anyone with repository access

If the repository is public, or leaked, the key is no longer secret - the encryption offers no protection

FAILURE: Confidentiality fails - encryption is only as strong as the secrecy of the key

Misuse 4 - Encrypting a message without also verifying Authenticity

Encryption hides the content - it does not prove who sent it

An attacker can substitute a different encrypted message from a different sender

FAILURE: Authenticity fails even though Confidentiality holds - the system trusts the wrong sender

The fix: digital signatures + encryption together - one protects content, the other proves origin

APP-02 (secrets from vault) is the SRS requirement that prevents Misuse 3. Secrets must be stored in a managed vault - not in code, config files, or environment variables visible in process listings.

Activity - Right Tool for the Job

Task

For each of the 8 scenarios on the right: (1) name the cryptographic property required, and (2) name the correct tool. Justify your choice in one sentence.

Discussion after each scenario

What would break if you chose Integrity instead of Authenticity?

Important

Two scenarios are Authenticity traps - the answer is NOT Integrity even though both properties relate to messages. Name Authenticity precisely.

Reading and reasoning only - no coding required

1. Store patient records so they cannot be read if the database is stolen
2. Verify a downloaded file has not been corrupted in transit
- 3. Prove this software update came from the vendor - not a third party**
- 4. Confirm the server is the real bank - not an impersonator**
5. Ensure a financial transaction cannot be denied later by the sender
6. Store a login password in a way that it can never be retrieved
7. Protect a message from being read while crossing an untrusted network
8. Ensure a config file loaded by a server was not altered since it was published

Scenarios 3 and 4 are Authenticity traps

The Authenticity Traps - Debrief



Scenario 3 - "Prove this software update came from the vendor, not a third party"

The property is Authenticity - not Integrity

Integrity only confirms the file has not changed. It says nothing about who published it.

A file can have a valid hash but be signed by a malicious actor masquerading as the vendor.

Scenario 4 - "Confirm the server is the real bank - not an impersonator"

The property is Authenticity - not Integrity

An impersonating server can serve content with perfect integrity. The hash checks pass. But the source is wrong.

The evaluator test: when you write an SRS requirement for this, which property does the acceptance test verify?

This distinction - Integrity vs Authenticity - appears in your Part B (B5 data protection, B3 network security) and in the viva

Discussion

What would fail if Integrity was satisfied but Authenticity was not?

Think of a scenario from your assigned coursework domain. Name the property that fails and the layer at which the failure occurs.

5 minutes - pairs or trios. One spokesperson per group to share back.

Lab - TLS Certificate Inspection



Goal - evaluate what a TLS certificate tells you about the Authenticity property of a real system

- Open your browser and navigate to any HTTPS website
- Click the padlock icon in the address bar - then "Connection is secure" or "Certificate is valid"
- On Chrome: More tools > Developer Tools > Security tab > View Certificate
- On Firefox: padlock > Connection secure > More Information > View Certificate
- You will now see the full certificate details - subject, issuer, validity, algorithm, key length
- **Inspect THREE websites - at least one must be from your assigned coursework domain**

Domain reminder: index mod 6 - 0 Banking, 1 Healthcare, 2 Transport/Aviation, 3 Education, 4 Ecommerce/Retail, 5 Hospitality. Pick a representative public-facing site from your domain.

Lab - What to Record for Each Certificate

Field to Inspect	Where to Find It	What You Are Evaluating
Algorithm and key length	Signature algorithm field	RSA 2048+ or ECDSA P-256+ is current good practice
Expiry date (Valid To)	Validity period section	Expired means Authenticity cannot be verified by a browser
Issuing CA (Issued By)	Issuer field	Is this a well-known, browser-trusted CA? (DigiCert, Let's Encrypt, etc.)
Certificate chain validity	Certification Path / Chain	Root CA trusted? Intermediate CA present and valid?

For each site: record the four fields above, then answer - what would a weak or expired certificate mean for the Authenticity property of this system?

Lab - Authenticity Impact of Certificate Failures

For the site from your assigned coursework domain, write 5 lines answering:

- What does the certificate prove about this server?
- Which entity issued the certificate, and why does that matter?
- What would an expired certificate mean for a user of this system?
- What would a self-signed certificate mean for the Authenticity property?
- Which SRS requirement would mandate that valid, CA-signed certificates must be maintained?

Not in scope for this lab

TLS configuration grading (cipher suites, protocol versions, SSL Labs scores) - that is Session 10. Today the question is only: what does this certificate prove about Authenticity?

Layer: Network - Property: Authenticity - SRS link: NET-01 (no public DB), APP-01 (certificate validation)

Coursework Connection



DATA Layer - SRS Requirements

DATA-01

All personally identifiable data at rest must be encrypted. Students can now write a testable acceptance criterion for this requirement.

DATA-02

Encryption key management and rotation. Hardcoded keys (Misuse 3) are the specific failure this requirement prevents.

B5 - Data Protection (Part B)

Students can now evaluate whether a system's cryptographic choices correctly enforce the properties they are intended to enforce.

APP + Network - Authenticity References

APP-01 - Input validation / output encoding

Can now explicitly reference certificate validation and signature verification as Authenticity controls at the Application layer.

NET-02 - WAF and rate limiting

TLS configuration and certificate validity are now evaluable as Authenticity controls at the network perimeter.

Demo - Open [AvalancheHasher.html](#)

Change one character - the entire hash transforms. Compare one-way hashing vs reversible encryption side by side.

Questions & Answers



Any questions on Session 3 - Cryptography: Properties, Not Mechanics?

Next - Session 4: Authentication - Passwords, Sessions and Tokens

S3

Disclaimer and Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While every effort is made to keep information accurate and up to date, no representations or warranties of any kind, express or implied, are made about the completeness, accuracy, reliability, suitability, or availability of the content.

This presentation may include references or links to third-party websites or content. These are not endorsed. The presenter is not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented is strictly at your own discretion. No liability is accepted for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

© Images and artworks used in this presentation are used for general informational purposes only and may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is made available in an effort to explain issues relevant to the topic and should constitute fair use of any such copyrighted material.

Last modified: 26 Jun 2026